

ZHIDUN AI SECURITY INTELLIGENCE

智能体驱动的 AI 安全知识情报系统

多源监测 · 证据富化 · 可追溯问答的 AI 安全情报闭环

参赛赛题 赛题九 · 网信产业应用赛道

命题单位 奇安信科技集团股份有限公司

赛事 第三届“中国电子杯”高校 ICT 产教融合创新大赛 · 校内初赛

证据先于结论 · 每条情报可回溯原始出处



AI 安全情报的三重困境与我们的答案

信息过载

漏洞散落在 CVE/NVD、社区、厂商公告、论文、博客，人工跟踪不可持续

覆盖缺失

传统情报系统面向通用漏洞，对 AI 框架、模型层、智能体风险缺乏深度覆盖

决策断层

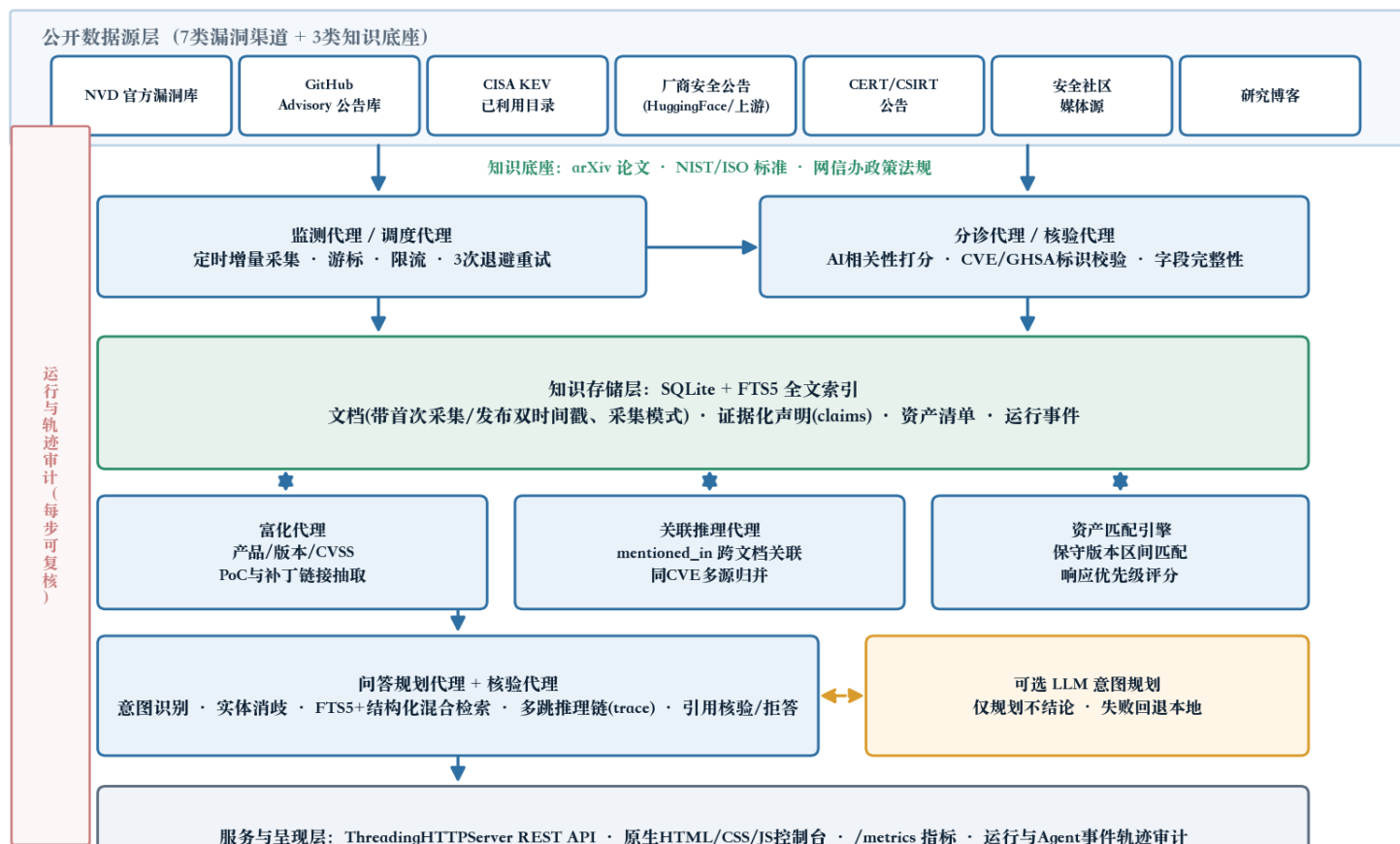
缺少自然语言问答与证据链，难以支撑“影响哪些资产、如何处置”的应急决策

知盾将分散情报组织成可审计知识库，以带来源的问答支持处置；证据不足时明确拒答。



总体架构：六层流水线 + 全程审计

图1 知盾系统总体架构



零依赖内核

Python 标准库 + SQLite/FTS5，断网无Key 可完整演示

单一事实源

文档与证据化声明分离存储，双时间戳 + 采集模式

受控增强

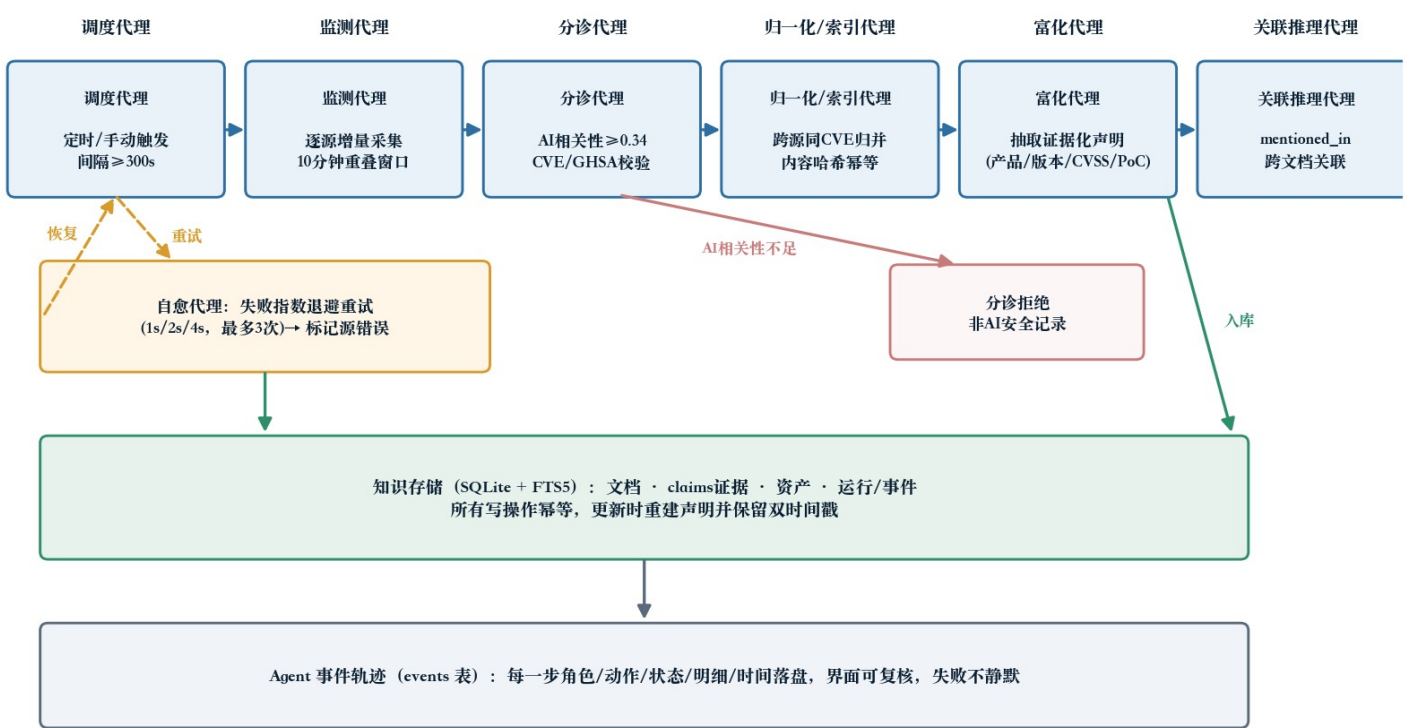
可选 GLM-5.3 规划问题并选择公开证据段落；失败回退

工程基础

REST API / 指标 / Docker / CI 配置；运行记录待补

10 类角色事件：规则编排、失败留痕

图2 情报处理流水线的 Agent 编排与失败自愈



角色名称标识确定性代码步骤；标签数量不等于独立自主 Agent 数。GLM-5.3 仅规划意图并选择本地公开证据段落。

12 个在线配置： 9 个监测候选 + 3 个知识源

官方漏洞库

NVD CVE API 2.0 (支持 API Key)

开源公告库

GitHub Advisory + OSV.dev (来源可重叠)

政府已利用目录

CISA KEV Feed (置信度 0.98)

厂商博客候选

HuggingFace 通用博客经关键词过滤

CERT 公告

CISA 网络安全通告

安全社区媒体

BleepingComputer + 安全客 RSS

研究博客

NIST Cybersecurity Insights

知识底座

arXiv 论文 · NIST 标准新闻 · 网信办政策

增量游标 + 10 分钟重叠窗口

容忍乱序发布；入库幂等保证重叠不产生重复实体

内容哈希双级去重

同源变更原位更新；跨源同 CVE 自动归并

时效度量内建

双时间戳 + demo/live 模式标记，P50/P95 延迟经 /metrics 暴露

失败自愈

指数退避重试 3 次 → 源隔离 + 健康度跟踪

注：一次全源运行 10/12 任务成功、入库 442 篇；2 源 HTTP 403。7 类独立来源与 $\leq 6h$ 延迟仍待持续验证。

来源字段抽取与规则富化

1	受影响产品与版本	来源字段映射 + 区间规范化
2	CVSS 与风险级别	数值校验, 缺失标“待评估”不记 0 分
3	修复版本与补丁链接	fixed 字段 + patch 标签参考
4	PoC 候选链接	离线样例无此项; 在线只收录元数据
5	相关论文 / 分析	显式提及或同产品规则关联
6	受影响资产匹配	授权清单 × 保守版本区间
7	处置优先级	CVSS × 暴露系数 × 关键度

claims 证据化声明模型

(subject, predicate, object)

- ▶ document_id → 挂接来源文档 (外键)
- ▶ evidence → 文档摘要摘录, 非逐字段原文
- ▶ confidence → 按来源类别分层 (KEV 0.98 ... 博客 0.62)
- ▶ 间接证据自动降权 (PoC 链接 - 0.12)

5 维深度富化和准确率仍待独立真值评测

三类规则关联：保留关系来源与理由

①

同 CVE 跨源归并

强关联

GitHub 公告 + Wiz 研究 → 同一漏洞证据组，多源分歧并列呈现，不由模型静默裁决

②

mentioned_in 显式提及

中关联

论文 / 综述正文提及某 CVE 即建立反向关联边；问答与详情页据此给出“哪些研究讨论了它”

③

产品重合推断

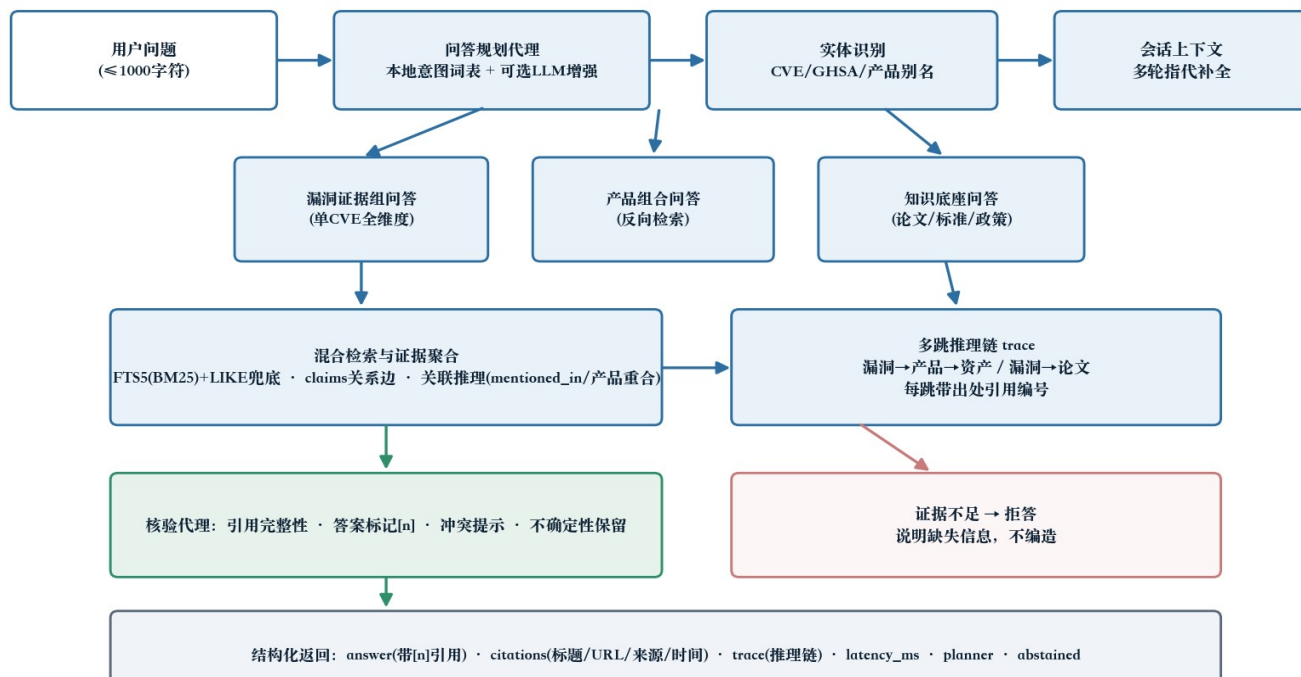
弱关联

文档未点名 CVE 但涉及同产品 → 标注为弱关联并明示“文档未直接提及该漏洞标识”

每条关联边在使用时输出关联理由与出处——“相关”不是黑盒，而是可检查的证据路径。

规则问答：来源引用、关系路径与拒答

图3 证据式问答执行流程（含多轮上下文与拒答分支）



当前可检查的规则路径

问：CVE-2024-37032 影响哪些资产、如何修复？

trace:

CVE → affects_product → ollama [1][2]

CVE → local_asset_version_match

→ 演示 - 虚构 -ollama 节点

证据：公告版本范围 + 本地授权清单

多轮上下文

省略主语追问

显式拒答

abstained + 缺失说明

可选 GLM

意图 + 证据选择，失败回退

安全边界：把不可控性锁进最小范围

不可信输入处理

网页按数据处理；GLM 接收问题与候选公开情报段落，不接收资产段落或数据库全文

注入与 Web 防线

严格 CSP · 跨源写入校验 · 1MB 请求上限 · 路径穿越防护

授权资产原则

只比对本地图录清单，不扫描、不探测任何陌生目标

PoC 只读不执行

仅收录元数据与链接，答案明示“系统不会执行验证代码”

拒答设计

实体不存在 / 证据不足 → abstained=true + 说明缺失，与引用核验一起纳入评测

自定 Agentic AI 安全样例 · 6/6 通过

参考 OWASP 建议作六攻击面映射；本地样例通过不等于外部认证或全面安全保证

工程基础：本地启动、接口与部署配置

一键启动

终端

python3 -m app.server
零第三方依赖 · 断网可演示

REST API

接口

问答 / 采集 / 详情 / 指标接口
请求校验与安全响应头

可观测

监控

运行与事件轨迹界面化
Prometheus /metrics 指标

容器化

部署

Dockerfile 非 root 运行
Compose 健康检查 + 命名卷

CI 回归

质量

GitHub Actions 配置单测
远端运行状态需另行核验

CLI 与评测

验收

cli.py 演示 / 统计 / 采集
evaluate.py 开发规则自测

离线开发规则自测： 9/9 通过

9/9

固定规则通过

基础 5+ 同 CVE 关联 3+ 拒答 1

11/11

必需引用存在

来源 ID 和 URL 与样例匹配

14/14

事实同行标记

不能代替来源内容核验

7/7

原样重放跳过

不代表在线去重准确率

评测项	结果	口径说明
单元测试	62/62 通过	连接器 / 归一去重 / 版本区间 / 拒答 /Agentic 自安全； 2026-09-29 本地回归
漏洞实体归并	3 实体 / 7 文档	同 CVE 双来源正确归并为证据组
资产匹配	3/3 符合预期	affected×2、not_affected×1，含区间边界用例
问答响应分布	以现场运行为准	单用户进程内 ask；无 HTTP/ 联网 / 模型，不能证明 ≤ 5s 档

口径：题目与 7 条人工摘要同源； 9/9 是规则通过率，不是语义准确率、富化召回率或官方评分。

设计特色与当前验证边界

01 证据化声明模型

富化重构为带出处、带证据片段、带置信度的 claims 三元组；多源分歧并列而非静默裁决

02 三类规则关联

同 CVE 归并 / mentioned_in 提及 / 产品重合推断，关联理由随答案输出

03 拒答作为一等能力

abstained + 缺失说明纳入评测题集，直接对抗情报系统幻觉风险

04 受控 GLM-5.3 增强

意图规划和公开证据段落选择；失败回退。一条真实 HTTP 问答已走通

05 自安全 + 可审计编排

OWASP 六攻击面自检为产品功能；10 类 Agent 每步决策落盘，自愈回路留痕

06 指标诚实工程

双时间戳 + 模式标记延迟统计、快照 / 在线三态区分，每项声明可复核

该原型把公开来源、人工整理摘要、本地资产版本匹配与带出处问答放在一套可离线复现的系统中。

如实标注的边界与可执行路线

当前如实未声称的

- ▶ 线上 ≥ 7 类源持续可用性与 $\leq 6h$ 采集延迟
- ▶ 富化准确率 / 召回率 $\geq 95\%$ 的人工真值评测
- ▶ 大规模题集语义泛化与多跳准确率
- ▶ 生产级高并发、完整 DevOps 实测

验收路线

在线持续运行实测

逐类源成功率与 $\leq 6h$ 延迟分布；归档原始批次

富化真值评测集

分维度 TP/FP/FN 人工标注、双人复核 $\rightarrow$ 准确率 / 召回率

语义检索增强

本地嵌入模型向量召回 + FTS5 混合排序；题集扩至 50+ 并分离留出集

GLM-5.3 效果对照

扩展当前单条 HTTP 验收，用留出题集比较质量和延迟

下一步先归档在线原始记录，再建立独立人工真值集，按赛题档位复测。



让每条安全情报 有来源、有关联、有答案。

现场演示: `python3 -m app.server --no-scheduler` → `http://127.0.0.1:8765`

知盾 ZhiDùn · 赛题九 网信产业应用赛道 · 第三届“中国电子杯”